

Cultivo Espacial — Deep dive estratégico

Fecha: 2026-06-14 · **Autor:** Claude (ingeniería + CTO + producto + CEO)

Acompaña a: [INFORME_EMPRESA_2026-06.md](#) (este profundiza cada sección con detalle accionable)

Cómo leer esto: es largo a propósito. No lo leas de corrido. Es material de consulta —

cada sección es un mini-manual de un área que como fundador-analista vas a tener que dominar

o delegar con criterio. Donde hablo de temas legales, lo marco como "confirmá con un profesional":

*te doy lo suficiente para saber **qué pedir**, no para reemplazar al abogado.*

1. Empresa vs. producto — arquitectura de la compañía

1.1 El modelo mental correcto

Pensá en tres capas:

- **Cultivo Espacial (la empresa / holding):** la marca madre, la sociedad, el equipo, la cultura, la infraestructura compartida.
- **Plataforma (lo transversal):** autenticación, facturación, gestión de cuentas/tenants, identidad visual, storage, notificaciones, panel super-admin. Esto NO es de Club Cultivo: es de la empresa, y lo van a reusar todos los productos.
- **Productos (las líneas de negocio):** Club Cultivo es el #1. El #2 y #3 (relacionados) se montan sobre la plataforma.

Hoy todo está mezclado: la plataforma vive dentro de Club Cultivo. **No hay que separarlo ya** — sería over-engineering prematuro. Pero sí adoptar una regla de decisión: cada vez que construí algo nuevo, preguntate **"¿esto lo va a necesitar el segundo producto?"**. Si la respuesta es sí (ej: login, cobros, identidad de marca), construílo lo más desacoplado posible del dominio cannabis.

1.2 Arquitectura de marca

- **Marca madre fuerte, productos como sub-marcas:** "Club Cultivo, by Cultivo Espacial". Esto te deja lanzar el producto #2 sin reconstruir reputación.
- Cuando llegue el producto de datos del sector, probablemente sea otra sub-marca (ej: un "Cultivo Espacial Insights"). Tenerlo en la cabeza ahora evita pintarte a una esquina de naming.

1.3 Implicancia técnica concreta (sin hacerla aún)

Cuando el segundo producto aparezca, vas a querer **autenticación y facturación como servicios compartidos**. La decisión que importa hoy: no enterrar la lógica de cuentas/planes/cobros tan adentro del dominio cannabis que después no se pueda extraer. El **PlanEnforcer** y la gestión de clubs son los primeros candidatos a "esto en realidad es plataforma".

2. Monetización — profundo

2.1 Conceptos de SaaS que como fundador tenés que manejar (glosario aplicado)

- **MRR (Monthly Recurring Revenue):** ingreso recurrente mensual. Es ***la*** métrica del SaaS. 50 clubes a \$30.000/mes = \$1.500.000 MRR.
- **ARR:** MRR × 12. Lo que usan los inversores.
- **Churn:** % de clubes que se dan de baja por mes. Un churn de 5% mensual significa que perdés más de la mitad de tu base al año si no crecés. En SaaS B2B sano, < 3% mensual.

- **CAC (Customer Acquisition Cost):** cuánto te cuesta conseguir un club (marketing + ventas + tu tiempo).
- **LTV (Lifetime Value):** cuánto te deja un club en toda su vida = (ingreso mensual × margen) / churn. La regla de oro: **LTV/CAC > 3**.
- **Trial → conversión:** % de los que prueban y terminan pagando. Tu `plan_trial` ya existe; medí esto desde el día uno.

Por qué te importa: cuando busques inversión o decidas cuánto gastar en conseguir clubes, estas cinco letras son el idioma. No necesitás un MBA — necesitás medirlas.

2.2 Estrategia de precios (opciones concretas para Argentina)

El problema argentino: inflación. Cobrar un número fijo en pesos se licúa. Opciones:

- **Opción A — Anclar a USD (dólar MEP/oficial):** mostrás el precio en pesos pero ajustado a un valor dólar. Protege tu ingreso real. Es lo que hacen casi todos los SaaS argentinos serios. Contra: el cliente ve aumentos seguido.
- **Opción B — Pesos con ajuste trimestral por inflación (IPC):** más predecible para el cliente, requiere comunicar aumentos.
- **Opción C — Pesos fijos, absorbés la inflación:** solo viable si tus costos también son en pesos y el período es corto.

Recomendación: A (anclar a USD), con plan anual a precio congelado como incentivo (el club paga 10-11 meses por 12 y vos asegurás ingreso + bajás churn).

Estructura sugerida (números de ejemplo, ajustá a tu mercado):

- **Semilla:** barato o casi gratis — es el gancho de entrada, clubes chicos. Que prueben el producto.
- **Brote / Cosecha:** el grueso del ingreso. Acá está tu cliente típico.
- **Federación:** precio "hablemos" (enterprise), clubes grandes o cadenas.

El truco de negocio: el plan barato no es para ganar plata, es para **bajar la fricción de entrada** y después hacer que crezcan (expansion revenue). Un club que arranca en Semilla y a los 6 meses está en Cosecha es el patrón ideal.

2.3 Arquitectura de cobros (lo que falta construir)

Hoy: el super-admin asigna el plan a mano. No escala. Lo que necesitás:

```
Alta del club (self-service)
  → Trial automático (plan_trial = true, plan_activo_hasta = hoy + 14 días)
  → Club usa el producto
  → Antes de vencer: recordatorio + link de pago (Mercado Pago Suscripciones)
  → Pago OK → webhook MP → actualiza plan_activo_hasta (+1 mes) automáticamente
  → Pago falla → reintentos → si no paga, downgrade/suspensión automática
```

Las piezas técnicas (las puedo construir yo cuando digas):

- **Integración Mercado Pago Suscripciones** (preapproval): el club autoriza un débito recurrente.
- **Endpoint de webhook** que recibe los eventos de MP y mueve `plan_activo_hasta` / `plan` / suspende.
- **Onboarding self-service:** página pública de alta → crea el club + admin + trial sin tu intervención.
- **Estados de suscripción:** trial / activo / vencido / suspendido, con qué puede hacer el club en cada uno (ej: vencido = solo lectura, no pierde datos).

Ya tenés media base (`plan` , `plan_activo_hasta` , `plan_trial` , `SuscripcionTabView`). Falta el motor automático.

2.4 El producto de datos (la apuesta grande)

Tu visión de datos agregados del sector es válida y potencialmente más valiosa que las suscripciones. Pero:

- **Es un segundo producto**, no una feature. Tiene su propio modelo de negocio (¿quién paga? ¿clubes por benchmarking? ¿laboratorios? ¿investigación?).
- **Legal y éticamente exige:** consentimiento explícito del club (ya tenés `benchmark_opt_in`), **anonimización real** (no "borrar el nombre" — eso no es anonimizar; hay que evitar la re-identificación), y probablemente revisión legal de que el club pueda ceder esos datos.
- **No lo construyas todavía.** Pero cada dato que guardás hoy con buena estructura y timestamp es materia prima futura. Ya lo estás haciendo bien.

3. Legal y compliance — profundo

*Recordatorio: no soy abogado. Esto es para que sepas **qué contratar y qué preguntar**. La plata*

mejor invertida ahora es un abogado de protección de datos con experiencia en salud/cannabis.

3.1 Por qué esto es lo primero (no lo último)

Estás tratando **datos de salud de personas identificables**. En la jerarquía de datos, eso es lo más protegido que existe. Un manejo flojo no es "un riesgo a futuro": es exposición legal desde el primer paciente cargado. Y a diferencia del código, no se arregla con un deploy.

3.2 Marco argentino (lo que sé, confirmá detalles)

- **Ley 25.326 de Protección de Datos Personales** (régimen de habeas data). Los datos de salud son **datos sensibles** con protección reforzada: requieren consentimiento y no pueden tratarse libremente.
- **AAIP (Agencia de Acceso a la Información Pública)**: el organismo de control. Históricamente se registran las bases de datos. (Hay una reforma de la ley en discusión hace tiempo — un abogado actualizado te dirá el estado vigente.)
- **Rol legal**: el **club es el responsable** del dato (decide para qué se usa); **Cultivo Espacial es el encargado del tratamiento** (lo procesa por cuenta del club). Esa distinción define tus obligaciones y va escrita en el contrato.

3.3 Los documentos que necesitás (qué contiene cada uno)

- **Términos y Condiciones del servicio** — qué ofrecés, qué no, límites de responsabilidad, qué pasa si el club incumple, condiciones de pago, terminación.
- **Política de Privacidad** — qué datos recolectás, para qué, cuánto los guardás, con quién los compartís, derechos del titular, cómo ejercerlos. Obligatoria por ley apenas tratás datos personales.
- **DPA / Acuerdo de tratamiento de datos** (Cultivo Espacial ↔ cada club) — define que vos procesás datos por cuenta del club, con qué medidas de seguridad, qué hacés ante una filtración, qué pasa al terminar (devolución/borrado de datos).
- **Consentimiento del paciente** — el club debe obtener consentimiento informado del socio para cargar sus datos de salud. La app debería **facilitar registrarlo** (checkbox + fecha + versión del texto consentido).
- **SLA** (Acuerdo de Nivel de Servicio) — qué uptime prometés, qué pasa si no lo cumplís. Empezá conservador.

3.4 Derechos del titular — falta el flujo en la app

La ley da al paciente derecho de **acceso, rectificación y supresión** ("borrame"). Hoy la app no tiene un flujo formal de "exportar todos mis datos" ni "borrar mi cuenta y mis datos". A escala vas a recibir estos pedidos. Conviene tener:

- **Export de datos del paciente** (lo que se tiene de él).
- **Borrado/anonimización** con su rastro de auditoría (quién pidió, cuándo).
- Ojo: borrado vs. retención legal — algunos datos hay que conservarlos por obligación (dispensaciones para ARICCAME). El abogado define qué se borra y qué se anonimiza.

3.5 Cannabis — encuadre de responsabilidad

- Tu producto **es una herramienta**; el cumplimiento legal del cultivo y la dispensación es del **club**. Esto va explícito en los T&C: no sos co-responsable de la operación del club.
- El marco (REPROCANN/ARICCAME) es político y cambiante. Tené identificado a alguien (abogado o consultor) que siga la normativa, porque un cambio puede invalidar supuestos del producto.

3.6 Estructura societaria — pasos concretos

- **SAS (Sociedad por Acciones Simplificada)**: el vehículo ágil y barato para arrancar en Argentina. Se constituye relativamente rápido y online en varias jurisdicciones. Hablá con un contador/abogado societario.
- **Sin sociedad no podés facturar formalmente** → bloquea cobrarle a clubes con factura. Esto es prerequisite de monetizar.
- **Marca en INPI**: registrar "Cultivo Espacial" y "Club Cultivo" (~clases de software/servicios). Protege el nombre antes de hacerte conocido.

- **Acuerdo de socios / fundadores:** si entra alguien (socio, primer empleado con equity), definí participaciones y **vesting** (que la participación se gane con el tiempo, no de golpe) ANTES de necesitarlo. Los conflictos de socios matan más startups que la competencia.

4. Seguridad de datos — profundo y técnico

4.1 Multi-tenancy: el riesgo #1, con plan de mitigación

Hoy: cada query filtra por `club_id` a mano. Funciona, pero un olvido = datos de un club visibles para otro = incidente de datos médicos reportable.

Defensa en capas (lo que recomiendo, en orden):

- **Tests de aislamiento** (barato, ya): un shared example de RSpec que para cada endpoint cree dos clubes y verifique que A nunca ve datos de B. Congela la garantía y la corre el CI.
- **Concern de scoping único** (`Current.club` + un `default_scope` por tenant): centralizar el filtrado para que no dependa de recordarlo en cada controller.
- **Row-Level Security (RLS) de PostgreSQL** (la red de seguridad real): la base misma rechaza devolver filas de otro club aunque el código se equivoque. Es la diferencia entre "confiamos en que el dev no se olvide" y "es imposible por diseño". Para una plataforma que **vende aislamiento**, esto es lo que te deja dormir.

Puedo implementar 1 y 2 ya; 3 requiere una migración cuidadosa y la planeamos aparte.

4.2 Qué datos deberías estar cifrando (y hoy no)

Hoy solo ciframos credenciales de dispositivos. Pero tenés **datos clínicos en texto plano** (patología, notas clínicas, diagnósticos). Con **Active Record Encryption** (ya configurado) deberíamos cifrar a nivel campo lo más sensible: `notas_clínicas`, `patologia`, diagnósticos. Así, aunque alguien acceda a la base, esos campos son ilegibles sin las llaves. Es una mejora concreta y de alto valor de compliance.

4.3 Autorización — unificar (deuda de seguridad)

Tres mecanismos conviviendo + matriz muerta = superficie de error. El plan (del informe de ingeniería, hallazgo A1): una sola fuente de verdad de permisos, aplicada en `BaseController`, espejada en el frontend. Mientras esté fragmentado, cada endpoint nuevo es una oportunidad de exponer algo.

4.4 Auditoría

Ya implementamos la tabla `auditorias` para movimientos contables. A nivel empresa, deberías auditar también: accesos a datos de pacientes (quién vio qué ficha), cambios de permisos, logins. Para datos médicos, "quién accedió" es parte del compliance.

4.5 Secretos y accesos

- `RAILS_MASTER_KEY` y credenciales: documentá quién tiene acceso, dónde viven, y un plan de rotación. Hoy es informal.
- **Principio de menor privilegio:** vos sos el único con todo, pero cuando entre alguien, que tenga solo lo que necesita.
- Pensá un **gestor de secretos** (Doppler, 1Password, o los secrets de Render bien organizados) en vez de archivos sueltos.

4.6 Pentest / revisión externa

Antes de escalar fuerte, una **revisión de seguridad externa** (un pentest acotado) vale la pena. Para datos médicos, poder decir "nos auditó un tercero" es argumento de venta y reduce riesgo real.

5. Infraestructura y DevOps — profundo, con implementación

Esto es lo que sí puedo construir yo. Te detallo cada pieza para que sepas qué implica.

5.1 CI/CD (prioridad alta, esfuerzo bajo)

Hoy: no hay pipeline. Dependés de acordarte de correr los tests. Un día vas a deployar algo roto a producción con datos de pacientes.

Solución: GitHub Actions que en cada push corra rspec + vitest y **bloquee el merge/deploy si algo falla**. Boceto:

```
push → GitHub Actions:
  job backend: levanta Postgres+Redis, corre rspec (588 tests)
  job frontend: corre vitest (58 tests) + build
  si todo verde → permite deploy a Render
  si algo falla → bloquea y te avisa
```

Lo puedo dejar andando en una sesión. Es el cambio de mayor relación valor/esfuerzo de toda la infra.

5.2 Monitoreo de errores (prioridad alta)

Hoy: te enterás de los bugs cuando un club se queja.

Solución: Sentry (tiene tier gratis generoso). Captura cada excepción del backend y del frontend con el stack completo, el usuario, y el contexto. Pasás de "reactivo y a ciegas" a "lo veo y lo arreglo antes de que el club lo note". ~1 hora de setup.

5.3 Uptime / disponibilidad

Un monitor externo (UptimeRobot, Better Stack — tienen tier gratis) que pinguee la app cada minuto y te avise por mail/Telegram si se cae. Hoy no sabés si estás caído salvo que entres.

5.4 Backups — el que más importa

Render hace backups del Postgres administrado, pero:

- ¿Sabés cada cuánto? ¿cuánto retiene? ¿probaste **restaurar** uno?
- **Un backup nunca restaurado no es un backup**. Hacé un *drill*: restaurá el backup a una base temporal y verificá que los datos están. Documentá el procedimiento.
- Considerá un **backup propio adicional** (dump diario a R2, cifrado) para no depender de un solo proveedor. Con datos de pacientes, la redundancia es barata comparada con perderlos.

5.5 Staging / Producción

Ya tenés **cultivo-staging**. Formalizá: staging con datos ficticios, prod intocable, nada se prueba en prod. El flujo: feature → staging → verificar → prod.

5.6 Escala (cuando llegue, no ahora)

- A cientos de clubes: múltiples instancias del backend + balanceador. Ahí el **storage local muere** (por eso R2) y el **multi-tenancy manual se vuelve peligroso** (por eso RLS). Las dos cosas que estás resolviendo ahora son justo las que destraban la escala.
- CDN para assets (R2 ya lo da).
- Read replicas de Postgres cuando las lecturas pesen.
- Observabilidad de performance (APM) para encontrar queries lentas (los controllers gigantes y los N+1 que marqué en el informe de ingeniería van a doler a escala).

6. Organización y equipo — profundo

6.1 La secuencia de hires (cuándo sumar a quién)

No contratás todo junto. Orden típico y sano:

- **Asesor legal de datos/cannabis** (ya, externo, por horas) — no es empleado, es la inversión que destraba cobrar.
- **Contador** (ya, externo) — para la SAS y la facturación.
- **Primer dev** (cuando el producto te exija más manos que las tuyas o quieras bajar el bus factor) — perfil full-stack

que pueda tomar features end-to-end.

- **Soporte/Customer Success** (cuando pases ~10-15 clubes y la atención te coma el día) — alguien que atienda clubes y los haga exitosos (reduce churn).
- **Ventas/Growth** (cuando el producto esté sólido y quieras acelerar adquisición).

6.2 El primer dev: qué buscar

- Que pueda trabajar en Rails **y** Vue (es un stack acoplado).
- Más importante que el seniority: alguien que documente y no genere dependencia de sí mismo (no querés cambiar un bus factor 1 por dos bus factors 1).
- Considerá empezar part-time/freelance antes de un full-time.

6.3 Bajar el bus factor (lo más urgente que NO cuesta plata)

Hoy, si desaparecés, la empresa muere. Mitigación inmediata, gratis:

- **Documentación de operación:** cómo se deploya, dónde viven los secretos, cómo se restaura un backup, cómo se da de alta un club, qué hace cada job de Sidekiq. (Parte ya está en [docs/](#).)
- **Runbooks** de los procedimientos críticos (ver sección 9).
- Que el conocimiento viva en el repo, no en tu cabeza. Cada cosa que documentás es patrimonio de la empresa.

6.4 Tu rol como fundador-analista

- **Tu ventaja:** entendés el dominio y el problema del cliente. Eso es lo que la mayoría de los fundadores técnicos NO tiene. Es tu cancha — jugá ahí.
- **Lo que tenés que soltar:** la idea de hacer todo vos. Delegá legal y contable ya. Tu tiempo vale más decidiendo y entendiendo clubes que aprendiendo derecho de datos.
- **Lo que tenés que aprender (mínimo):** las 5 métricas de SaaS (sección 2.1) y a leer un estado contable básico. No más que eso.

7. Registro de riesgos — expandido (detección / prevención / respuesta)

#	Riesgo	Cómo lo detectás	Cómo lo prevenís	Qué hacés si pasa
R1	Fuga de datos entre clubes	Tests de aislamiento en CI; reportes raros	RLS + scoping central + tests	Contener, notificar AAIP/clubes, post-mortem
R2	Sin marco legal al cobrar	— (lo sabés ya)	Abogado + T&C + DPA antes del 1er cobro	Frenar cobros hasta regularizar
R3	Pérdida de base de datos	Alertas de backup fallido	Backups + drill de restauración	Restaurar del último backup verificado
R4	Bus factor = 1	—	Documentación + hire	(no hay "respuesta" — por eso se previene)
R5	No enterarte de caídas/bugs	Sentry + uptime monitor	Mismos	Responder rápido, comunicar a clubes
R6	Cobro manual no escala	Tiempo perdido cobrando	Pasarela + self-service	—
R7	Cambio regulatorio cannabis	Seguimiento normativo	Asesor + T&C que delimitan	Adaptar producto rápido
R8	Deuda técnica frena features	Velocidad que baja	Refactors graduales	Pagar deuda antes de escalar
R9	Concentración en un proveedor (Render)	—	Código portable (Docker), backups propios	Migrar (el Docker ayuda)
R10	Churn alto por mala experiencia	Medir churn mensual	Customer success + UX	Entrevistar a los que se van

8. Roadmap de empresa — con secuencia y dependencias

```
FASE 1 – "Vendible con tranquilidad" (lo que destraba cobrar sin riesgo)
Legal: SAS + marca + abogado datos → T&C, Privacidad, DPA, AAIP
Técnico: R2 (en curso) → backups probados → CI → Sentry/uptime → cifrar datos clínicos
Seguridad: tests de aislamiento + scoping central
– dependencia: legal y backups ANTES del primer cobro real

FASE 2 – "Cobrible a escala"
Mercado Pago Suscripciones + webhook + onboarding self-service
Definición de precios
Estados de suscripción (trial/activo/vencido/suspendido)
Soporte mínimo estructurado + SLA
– dependencia: Fase 1 legal lista

FASE 3 – "Escalable"
RLS en Postgres + unificar autorización + pagar deuda técnica
Escala horizontal + CDN + APM
Primer hire técnico + documentación de operación
– dependencia: monetización andando (justifica la inversión)

FASE 4 – "Plataforma / Holding"
Extraer servicios de plataforma (auth, billing, identidad)
Producto de datos sectoriales (con consentimiento + anonimización)
Segundo producto sobre la base de empresa
```

9. Runbooks (plantillas de procedimientos críticos)

Esto baja el bus factor. Completá los detalles reales y guardalos en `docs/`.

Runbook: La app está caída

- Confirmar (¿el monitor de uptime avisó? ¿podés entrar?).
- Ver logs en Render + errores en Sentry.
- ¿Fue un deploy reciente? → rollback al deploy anterior.
- ¿Es la base / Redis? → ver estado en Render.
- Comunicar a los clubes si dura > X minutos.
- Post-mortem: qué pasó, por qué, cómo se evita.

Runbook: Restaurar un backup

- Identificar el último backup válido.
- Restaurar a una base temporal (NO pisar prod directo).
- Verificar integridad de datos.
- Plan de cutover.

Runbook: Sospecha de fuga de datos

- Contener (cortar el acceso afectado).
- Determinar alcance (qué datos, de qué clubes).
- Notificar según obligación legal (AAIP, clubes) — el abogado define plazos.
- Documentar todo.
- Remediar la causa raíz.

Runbook: Alta de un club nuevo (hasta que sea self-service)

- Crear club + admin desde super-admin.
- Asignar plan + trial.
- Verificar onboarding.

10. KPIs que deberías mirar como empresa (tablero mental)

Negocio: MRR, nuevos clubes/mes, churn mensual, conversión trial→pago, ticket promedio.

Producto: clubes activos (que usan la app, no solo pagan), features más usadas, tiempo hasta primer valor (cuánto tarda un club nuevo en dispensar/cargar su primer lote).

Técnico/operación: uptime %, tasa de errores (Sentry), tiempo de respuesta, jobs fallidos.

Salud financiera: ingresos vs costos (Render + R2 + herramientas + asesores), runway (meses que aguantás con la plata que hay).

No necesitás un dashboard sofisticado ya. Una planilla con estos números actualizada cada mes te pone por delante del 90% de los fundadores.

Cierre

Lo repito porque es lo importante: **el producto ya lo tenés más resuelto que casi cualquier startup en esta etapa.** Lo que falta no es talento de producto — es el andamiaje de empresa. Y ese andamiaje, hecho ahora con pocos clubes, es barato y te da una base inquebrantable. Hecho después, con 100 clubes y un incidente encima, es caro y doloroso.

El orden es claro: **legal/datos → continuidad (backups/monitoreo/CI) → monetización → escala.** Construir features es tentador porque es lo que sabés hacer y da dopamina. Pero la próxima milla de valor para Cultivo Espacial no está en una pantalla nueva: está en poder mirar a un club a los ojos y decirle "tus datos están seguros, mi empresa es seria, y mañana sigo acá".